

Daily Vulnerability Report - 2026-09-10

Window (UTC): 2026-09-10T00:00 to 2026-09-11T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 09:53:52 UTC

Total	New	Updated	KEV	Critical	High	Medium	Unscored	Watchlist	Packages
1130	604	526	10	94	427	337	253	127	69

P1 - Act now (KEV / high EPSS)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704 Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-42016 Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018 Added to KEV			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-67277 Added to KEV			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.
CVE-2026-76460 Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461 Added to KEV			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-84869 Added to KEV			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706 Added to KEV			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-86060 Added to KEV			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-87886 Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.
CVE-2026-60004 New				0.868	Go:code.gitea.io/gitea, Go:gitea.dev fixed: 1.27.1	Gitea: Remote Code Execution via diffpatch Git Hook Installation in gitea.dev

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77770 New	10.0	CRIT		0.002		The miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress plugin before 19.3 does not require a validated transaction before deleting site options whose names come from unauthenticated request input, allowing any visitor to delete arbitrary options, which can lock every administrator out of the dashboard or deactivate every miniOrange 2FA WordPress plugin before 6.3.1, miniOrange 2FA WordPress...
CVE-2026-86152 Newly scored	10.0	CRIT		0.019		A flaw has been found in Tenda CP3 27.5.57.101. The impacted element is the function CAutoAddWifi::ThreadProc of the file Functions/AutoAddWifi.cpp of the component Kylin. Executing a manipulation can lead to os command injection. The attack may be launched remotely.
CVE-2026-19583 New	9.9	CRIT		0.006		Velociraptor allows some sensitive artifacts to be gated by additional permissions. For example, the Linux.Sys.BashShell artifact allows arbitrary command execution on endpoints, and so it requires the EXECVE permission to schedule. However, no such check was implemented for client monitoring artifacts. Additionally there was no requirement that client monitoring artifacts carry the CLIENT_EVENTS type. This allows...
CVE-2026-68487 New	9.9	CRIT		0.004		Path traversal in Plesk's Backup Manager causes arbitrary file write as root by an authenticated customer.
CVE-2026-68488 New	9.9	CRIT		0.002		A Time-of-check Time-of-use (TOCTOU) race condition leading to insecure symlink following in Plesk causes local privilege escalation to root via arbitrary file/directory ownership takeover.
CVE-2026-85165 Newly scored	9.9	CRIT		0.003	n8n:n8n	n8n versions before 2.36.2 contain an expression sandbox bypass vulnerability where free identifiers in spread, computed-key, switch-case, or class-extension positions resolve against process globals. Authenticated users with workflow-edit permission can mutate host objects through expression evaluation, with changes persisting process-wide until restart.
CVE-2026-89094 New	9.9	CRIT		0.005		Forgejo before 16.0.4 allows remote code execution via a crafted template repository because template expansion on files in .forgejo/template is mishandled.
CVE-2026-18351 New	9.8	CRIT		0.008		The Drag and Drop File Upload for Elementor Forms plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.6.0 via the elementor_file_upload function. This is due to insufficient file type validation in the is_file_type_valid() function, which uses the attacker-controlled 'type' parameter as regex keys in the MIME allowlist, allowing blacklist bypass via a crafted extensi...
CVE-2026-18658 Newly scored	9.8	CRIT		0.004		IBM Operational Decision Manager 9.6.0.0, 9.5.0.0, 8.11.1.0, 8.11.0.1, 8.12.0.1, 9.5.0.1, and 9.0.0.1 is vulnerable to SQL injection. An unauthenticated attacker can execute arbitrary SQL statements and leverage database functionality to write a web shell to the application web root, resulting in remote code execution.
CVE-2026-38626 New	9.8	CRIT		0.003		Garlic-Hub v1.0.1 is vulnerable to SQL Injection in src/Modules/Items/Repositories/ItemsRepository.php.
CVE-2026-47884 Newly scored	9.8	CRIT		0.004	vmware:spring_framework	Use of XsltView in a Spring MVC application can result in SSRF and RCE attack if the application has an "/"**" mapping that results in view rendering, and where the view name is not explicitly specified. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-52098 New	9.8	CRIT		0.008	flowiseai:flowise	An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowId> endpoint

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57967 New	9.8	CRIT		0.007	apache:artemis	An unauthenticated remote attacker can craft a CORE protocol SESSION_REATTACH packet to steal an existing session and assume ongoing execution of the previously authenticated session. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-69579 Newly scored	9.8	CRIT		0.01		Use after free in Windows Message Queuing allows an unauthorized attacker to execute code over a network.
CVE-2026-69715 Newly scored	9.8	CRIT		0.01		Out-of-bounds read in Windows Direct Show allows an unauthorized attacker to execute code over a network.
CVE-2026-69730 Newly scored	9.8	CRIT		0.011		Use after free in Windows DNS allows an unauthorized attacker to execute code over a network.
CVE-2026-69768 Newly scored	9.8	CRIT		0.009		Heap-based buffer overflow in Windows RNDIS allows an unauthorized attacker to execute code over a network.
CVE-2026-69824 Newly scored	9.8	CRIT		0.01		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an unauthorized attacker to execute code over a network.
CVE-2026-69845 Newly scored	9.8	CRIT		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-7188 New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows SQL Injection. This issue affects Access Control System: before Versiyon 2.
CVE-2026-73778 Newly scored	9.8	CRIT		0.003	hpe:aruba_cx_10000-48y6c_(r8p13 a), hpe:aruba_cx_10000-48y6c_(r8 p14a), hpe:aruba_cx_10000-48y6c _(s0f98a), hpe:aruba	A vulnerability exists in the Credential Manager component that may allow for unauthorized administrative access. An unauthenticated remote attacker could exploit this vulnerability on a device in its factory-default or post-ZTP state before any administrator has configured credentials by providing a predictable factory-default password. Successful exploitation could result in full administrative control of the af...
CVE-2026-77493 Newly scored	9.8	CRIT		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Double free in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78573 New	9.8	CRIT		0.004	ibm:contextforge	IBM ContextForge MCP Gateway 1.0.0 through 1.0.7 could allow a remote attacker to gain administrative access due to the use of default credentials.
CVE-2026-79724 New	9.8	CRIT		0.005	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary OS commands due to improper neutralization of special elements used in an OS command.
CVE-2026-80351 New	9.8	CRIT		0.005	apache:camel	Improper neutralization of directives in dynamically evaluated code ('eval injection') vulnerability in Apache Camel K. An improper neutralization of directives in dynamically evaluated Maven configuration allows tenant-controlled repository content to influence code execution within the operator pod, potentially enabling tenants to execute arbitrary code with the privileges of the operator. This issue affec...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80352 New	9.8	CRIT		0.004	apache:camel	Improper Control of Generation of Code ('Code Injection') vulnerability in Apache Camel K. A YAML injection vulnerability in custom resource configuration allows an authorized CR author to inject arbitrary Kubernetes objects, potentially enabling unauthorized resource creation with the privileges of the operator. This issue affects Apache Camel K: from 2.0.0 before 2.9.3, from 2.10.1 before 2.10.2. Users ...
CVE-2026-81204 New	9.8	CRIT		0.006	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 could allow a remote attacker to execute arbitrary code due to code injection during graph construction.
CVE-2026-81467 New	9.8	CRIT		0.038	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10. 2616, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Command execution.
CVE-2026-85025 New	9.8	CRIT		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-85216 Newly scored	9.8	CRIT		0.005	misp-project:misp	MISP contains an authentication bypass vulnerability in its LDAP and LinOTP authentication components due to insufficient validation of user-supplied credentials. The custom LdapAuthenticate and LinOTPAAuthenticate components replace CakePHP's FormAuthenticate implementation but did not replicate its credential validation checks. As a result, empty or non-string values could reach the underlying authentication mec...
CVE-2026-88018 New	9.8	CRIT		0.005	rclone:rclone fixed: 1.75.1	rclone is a command-line program to sync files and directories to and from different cloud storage providers. Prior to 1.75.1, rclone serve s3 configured with --auth-proxy but without --auth-key allows authPairMiddleware to register any client-chosen accessKeyID with an empty ws.s3Secret. gofakes3 then verifies the request's SigV4 signature against that same empty secret, while Server.auth passes the access key id...
CVE-2026-88278 New	9.8	CRIT		0.003		GeoVision GV-LPC2211 V1.13 fails to enforce WS-Security UsernameToken freshness or nonce reuse protection, allowing a captured PasswordDigest token to be replayed for subsequent ONVIF operations.
CVE-2026-9163 New	9.8	CRIT		0.003		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection. This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.
CVE-2026-82107 New	9.6	CRIT		0.003	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information and bypass security restrictions due to improper authentication.
CVE-2026-44950 New	9.5	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) copies each glyph's bitmap into a single buffer. Existing checks validates only that the source slice (position, length) lies within the source bitmap buffer. It does not check whether the running destination cursor has exceeded the allocation. A malicious font server can send overlapping source offsets -- for example 1000 glyphs each referenc...
CVE-2026-65639 New	9.5	CRIT		0.016		OS command injection in the advanced-rule parser of ConfigServer Security & Firewall allows a remote attacker who controls a configured allow/deny feed to execute arbitrary commands as root, due to insufficient validation of feed-supplied rule data. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnera...
CVE-2026-88062 New	9.5	CRIT		0.009	npm:omniroute	OmniRoute is an open-source AI gateway providing a single endpoint for multiple model providers. In 3.8.49 and earlier, the OmniRoute POST /api/acp/agents custom ACP agent endpoint accepted attacker-controlled binary and versionCommand values and used only a self-consistency check before execFileSync executed the selected interpreter and arguments. The same request called refreshAgentCache, and resolveVersionProbe...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81046 New	9.4	CRIT		0.004	dell:latitude_3330, dell:latitude_3420, dell:latitude_3440, dell:latitude_3450, dell:latitude_5440, dell:latitude_5450,	Dell ThinOS 10, versions prior to 2605_10.2616, contain a Protection Mechanism Failure vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Arbitrary Code Execution within the application context.
CVE-2026-82533 Newly scored	9.4	CRIT		0.006		DeepSeek Harness before 0.1.2-alpha.1 contains an authentication bypass vulnerability that grants unauthenticated access to its local HTTP agent-control API by accepting a client-supplied loopback Host header in place of validating the actual TCP connection origin. On the default configuration, a confined tool-executed process can reach the loopback API without any port exposure and use it to escape its own OS san...
CVE-2026-84200 Newly scored	9.4	CRIT		0.002		Kyverno versions v1.9.0 through v1.12.7 contain a policy exception handling flaw. When a policy in enforce mode is combined with two PolicyExceptions, the less restrictive exception takes precedence, allowing an attacker to bypass the policy by crafting a resource name that matches the second exception's name pattern (e.g., *ingress*). This can be used to circumvent policies such as one blocking hostPath volumes...
CVE-2026-85695 Newly scored	9.4	CRIT		0.004		FastChat contains an authentication bypass vulnerability in the /register_worker endpoint that allows unauthenticated attackers to register arbitrary worker addresses and perform server-side request forgery. Attackers can register malicious workers under victim model names to intercept user prompts, images, and responses, or probe internal network ports across the worker mesh.
CVE-2026-88285 New	9.4	CRIT		0.003		GeoVision GV-LPC2211 V1.13 exposes a network-accessible PTZ control service without authentication, allowing remote clients to retrieve PTZ information and issue PTZ or raw serial commands.
CVE-2023-54356 Newly scored	9.3	CRIT		0.001		Kyverno versions 1.9.4 and earlier support insecure 3DES cipher suites (TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA and TLS_RSA_WITH_3DES_EDE_CBC_SHA) on their TLS endpoints. These 64-bit block ciphers are vulnerable to the Sweet32 attack (CVE-2016-2183), which, over very long-lived TLS connections carrying large volumes of traffic, could allow an attacker to recover small amounts of plaintext. The issue is fixed in Kyver...
CVE-2026-44402 Newly scored	9.3	CRIT		0.009		Voltronic Power SNMP Web Pro 1.1 contains an unauthenticated remote code execution vulnerability in the upload.cgi firmware update endpoint that allows remote attackers to execute arbitrary commands as root by uploading a crafted tar archive without valid credentials. Attackers can supply a malicious tar archive containing arbitrary executable files that are extracted to a privileged directory and executed as root...
CVE-2026-69356 Newly scored	9.3	CRIT		0.007		Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Exchange Server allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-75940 New	9.3	CRIT		0.003		A vulnerability was reported in Lenovo Health Android Application, distributed exclusively in the Chinese market, that could allow an attacker to access sensitive health-related information.
CVE-2026-78082 New	9.3	CRIT		0.005		Joomla Extension - joomshaper.com - Unauthenticated SQL Injection in Property Search and Map Filtering in SP Property < 4.1.4 - The property search and listing query builders assembled several WHERE and ORDER BY clauses (zipcode, sorting, price_range_dropdown, and psize_range_dropdown) by directly concatenating raw request parameters into SQL strings without quoting or type casting. An unauthenticated remote attac...
CVE-2026-79782 Newly scored	9.3	CRIT		0.001		rc1one before 1.74.4 fails to strip the X-Amz-Security-Token header when an S3 redirect changes scheme from HTTPS to HTTP on the same host. Attackers can intercept plaintext HTTP traffic to capture AWS STS session tokens sent in request headers.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80428 Newly scored	9.3	CRIT		0.023		ILIAS before versions 9.22, 10.10, and 11.3 contains an unauthenticated PHP object injection vulnerability that allows unauthenticated attackers to execute arbitrary code by injecting serialized objects through the LTI authentication endpoint and triggering deserialization via the Shibboleth back-channel logout endpoint. Attackers can write arbitrary serialized objects into session storage, then exploit an availab...
CVE-2026-81800 New	9.3	CRIT		0.002		Unauthenticated SQL Injection in Verified Reviews (Avis Vérifiés) <= 2.4.6 versions.
CVE-2026-82854 Newly scored	9.3	CRIT		0.011		Nodemailer before 8.0.4 is vulnerable to SMTP command injection through the unsanitized envelope.size parameter. When an application passes a custom envelope object with a size property containing CRLF characters to sendMail(), the value is concatenated into the SMTP MAIL FROM command (as SIZE=...) without sanitization, allowing injection of arbitrary SMTP commands such as RCPT TO to silently add attacker-controll...
CVE-2026-82859 Newly scored	9.3	CRIT		0.003		hulumi versions before v1.3.2 contain a deployment SCP template that allows tag-on-create bypasses for hulumi:iac-role protections. Attackers can bypass intended IAM boundary restrictions by exploiting the weakened SCP template in downstream deployments.
CVE-2026-82876 Newly scored	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware verifies RSA signatures using a public modulus embedded within the firmware image itself rather than anchored in immutable storage. Attackers can generate arbitrary RSA key pairs, sign modified firmware with the private key, embed the matching modulus in the signature segment, and the controller accepts the tampered firmware as valid.
CVE-2026-8323 New	9.3	CRIT		0.003		URL redirection to untrusted site ('open redirect') vulnerability in Armiya Information Technologies Ltd. Co. Access Control System allows Fake the Source of Data. This issue affects Access Control System: before Versiyon 2.
CVE-2026-84696 Newly scored	9.3	CRIT		0.001		Phison PS3111-S11 controller firmware versions through SBFQT1.3 expose privileged vendor unique commands over the ATA interface with absent or defeatable authentication mechanisms. Attackers can bypass the weak CRC-16 based unlock handshake or exploit builds with no VUC lock to read and write controller memory and raw flash, persisting implants across power cycles.
CVE-2026-85183 Newly scored	9.3	CRIT		0.002		Taipy configures its socket.io server with wildcard CORS origin and credential flag enabled, allowing any web page to establish credentialed WebSocket connections to victim applications. Attackers can open socket.io sessions from arbitrary domains and invoke state variable modifications and action callbacks without CSRF protection.
CVE-2026-85663 Newly scored	9.3	CRIT		0.005		Aim 3.29.1 remote tracking server fails to authenticate requests and dispatches arbitrary methods through getattr without allowlist validation. Unauthenticated attackers can register clients, instantiate Repo resources, and invoke arbitrary methods to read experiments or delete runs.
CVE-2026-85667 Newly scored	9.3	CRIT		0.004		xiaobei through 5.5.2 fails to implement authentication or signature validation on webhook endpoints, allowing unauthenticated attackers to inject arbitrary messages into the agent pipeline. Attackers can publish malicious messages via the /webhook_worktool handler and exploit unvalidated media URL fetching to perform server-side request forgery against internal services.
CVE-2026-85696 Newly scored	9.3	CRIT		0.015		SadTalker contains an OS command injection vulnerability in the video muxing process where uploaded audio filenames are interpolated into ffmpeg commands without proper escaping. Attackers can upload audio files with shell metacharacters in the filename to break out of quoted arguments and execute arbitrary system commands when video generation occurs.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88864 New	9.3	CRIT		0.003		Capgo (capgo.app) fails to restrict direct write access to the public.sso_providers table exposed through Supabase PostgREST. A holder of an ordinary Capgo full API key can insert a row with status='active' and enforce_sso=true, bypassing the intended backend SSO provisioning route (supabase/functions/_backend/private/sso/providers.ts) and its controls: the Enterprise plan requirement, SSO provider creation via th...
CVE-2026-88866 New	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the Login History page, allowing script execu...
CVE-2026-88867 New	9.3	CRIT		0.003		WWBN AVideo, in versions up to and including commit c3edcc274c389816d434acadac07ee78eaf330c1, contains a stored cross-site scripting vulnerability. objects/categoryAddNew.json.php passes the POST parameters `name` and `iconClass` to Category::setName() and Category::setIconClass(), which store the values without sanitization (setName only truncates to 45 characters). The category name is later echoed as HTML text ...
CVE-2026-88868 New	9.3	CRIT		0.003		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LiveLinks plugin where title and description fields are stored without sanitization. A user with canStream permission can inject malicious scripts that execute in the browser of every visitor viewing the live-link page, including administrators, within the site origin.
CVE-2026-88869 New	9.3	CRIT		0.005		AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the AD_Server plugin's log.php endpoint that fails to escape the label parameter before storage. An unauthenticated attacker can inject malicious HTML through the label parameter, which is later rendered unsanitized in the admin Ad Types report using jQuery .html(), allowing execution of arbitrary...
CVE-2026-88877 New	9.3	CRIT		0.004	traefik:traefik	Traefik is a HTTP reverse proxy and load balancer. In versions >= v3.7.0 and <= v3.7.11, the Kubernetes ingress-nginx provider mishandles Ingresses that carry both an authentication annotation and the nginx.ingress.kubernetes.io/from-to-www-redirect annotation. For such Ingresses the provider creates an additional 'sibling' router that matches on the host alone, carries only the RedirectRegex middleware, and still...
CVE-2026-88899 New	9.3	CRIT		0.004		knowns versions before 0.31.0 fail to properly validate the x-opencode-directory request header in the /api/opencode proxy endpoint. Remote attackers can supply arbitrary directory paths to execute file operations outside the project root on the host system.
CVE-2026-89042 New	9.3	CRIT		0.003		passport-saml-encrypted through 0.1.13 makes SAML signature verification conditional on an optional cert option, allowing attackers to bypass authentication by submitting unsigned SAML responses. Attackers can post forged SAML responses with arbitrary NameID and attributes to the assertion consumer service endpoint to receive authenticated profiles without valid signatures.
CVE-2026-13745 New	9.2	CRIT		0.003		A vulnerability in the Gemini CLI and associated GitHub Action allowed an unprivileged attacker to achieve an arbitrary code execution in Gemini CLI via untrusted local .env files overriding GEMINI_CLI_HOME.
CVE-2026-59679 New	9.2	CRIT		0.004		fs_read_glyphs() in the libXfont2 font-server client (src/fc/fserve.c) indexes the per-character encoding[] array using num_chars from the FS_QueryXBitmaps16 reply, but that array was allocated with a size derived from num_extents in the separate FS_QueryXExtents16 reply. The two CARD32 fields are never cross-checked. A malicious or compromised font server can send a small num_extents (e.g. 1) in the extents reply...
CVE-2026-65638 New	9.2	CRIT		0.032		Improper escaping of a request URL in ConfigServer Security & Firewall allows an unauthenticated remote attacker to execute arbitrary commands as the CSF service account via shell command injection. The vulnerability affects versions of the software originally distributed by ConfigServer, as well as versions of the WebPros-maintained fork that contain the vulnerable code. WebPros has addressed the vulnerability ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85694 Newly scored	9.2	CRIT		0.005		LaVague 0.2.35 contains a remote code execution vulnerability in PythonFromMarkdownExtractor.extract_as_object that evaluates untrusted language model output derived from web page content. Attackers can inject malicious Python code through web pages using indirect prompt injection to execute arbitrary code on the operator's host without review.
CVE-2026-86117 Newly scored	9.2	CRIT		0.004		Coolify through 4.3.17 contains an authentication bypass vulnerability in the OAuth callback handler that signs users into existing accounts based solely on email address without verifying provider assertions or binding OAuth identities. Attackers can register a victim's email address on any enabled OAuth provider to obtain authenticated sessions as that user, bypassing password requirements and two-factor authentic...
CVE-2026-88881 New	9.2	CRIT		0.003		Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the 'next' page. Because the pagination URL is not validated against the host originally contacted, a malicious or compromised GitHub server ...
CVE-2026-88882 New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. In versions before 44.11.2 (and Mend Renovate CE/EE images and charts before 15.4.0, and mend-renovate-enterprise-edition helm chart before 10.4.0), when listing new package versions from a NuGet registry Renovate follows pagination URLs supplied by the registry in the HTTP `Link` header without verifying that the target has the same origin as the configured registr...
CVE-2026-88887 New	9.2	CRIT		0.003		Renovate is a dependency update automation tool. When listing tags/digests for a container image, Renovate follows pagination links supplied by the remote registry in the HTTP Link header and attaches the registry credentials to the follow-up request without verifying that the pagination URL has the same origin as the original registry. A malicious or compromised container registry can therefore specify a Link hea...
CVE-2026-19646 New	9.1	CRIT		0.005		IBM Common Licensing Agent 9.0, Agent 9.0.0.1, Agent 9.0.0.2, ART 9.0, ART 9.0.0.1, and ART 9.0.0.2 could allow a remote attacker to redirect users to an arbitrary domain due to improper validation of the HTTP Host header.
CVE-2026-45764 New	9.1	CRIT		0.004	oisf:suricata	Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine. Prior to versions 7.0.16 and 8.0.5, a protocol change while processing HTTP/2 traffic could lead to type confusion in Suricata. Crafted traffic may cause Suricata to crash, resulting in denial of service. Versions 7.0.16 and 8.0.5 contain a fix. As a workaround, disable HTTP/2 parsing if it is not ...
CVE-2026-49364 New	9.1	CRIT		0.004	apache:artemis	An unauthenticated network-adjacent attacker can leverage discovery to capture cluster administrative credentials during the initial cluster connection handshake. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-62646 Newly scored	9.1	CRIT		0.003		A vulnerability has been identified in Reyrolle 7SR5 (All versions < V2.70). A session identifier is generated using an algorithm with insufficient randomness, resulting in a token with low entropy that can be predicted or brute-forced within a feasible number of attempts. This could allow an unauthenticated remote attacker to derive valid session identifiers and bypass authentication.
CVE-2026-67593 New	9.1	CRIT		0.006	apache:artemis	A remote attacker can craft an Openwire RemoveSubscriptionInfo command to cause the deletion of a queue on the Artemis broker before the connection authentication and authorization stage or at any time thereafter. This issue affects Apache Artemis: from 2.50.0 through 2.56.0; Apache ActiveMQ Artemis: from 1.0.0 through 2.44.0. Users are recommended to upgrade to version 2.57.0, which fixes the issue.
CVE-2026-68006 New	9.1	CRIT		0.004		An issue in Puma v.5.0.0 and before v.8.0.3 allows an attacker to execute arbitrary code via the ext/puma_http11/http11_parser.rl file

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71640 New	9.1	CRIT		0.004		An issue in ZJU-FAST-Lab EGO-Planner-v2 All versions up to commit 5c99a95880401e2599638d567abc0e240396cb42 allows unsafe vehicle motion via improper handling of expired trajectory data in the replanning pipeline
CVE-2026-78361 New	9.1	CRIT		0.003		The zipMoney(Zip Co) Payments Plugin for WooCommerce WordPress plugin before 2.4.0 does not perform any authorisation checks on one of its front-end request handlers, and does not restrict which option name a caller may supply, allowing unauthenticated users to delete arbitrary WordPress options. This can be used to destroy site and access control configuration, deactivate every installed zipMoney(Zip Co) Payments...
CVE-2026-80424 New	9.1	CRIT		0.004	ibm:datastage_on_cloud_pak_for_data	IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to create arbitrary files due to path traversal during archive extraction.
CVE-2026-84939 New	9.1	CRIT		0.008	apache:freemarker	Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled). This issue affects Apache FreeMarker from 2.2.0 through 2.3.34. Users are recommended to upgrade to version 2.3.35. Disabling localized lookup in previous versions also...
CVE-2026-85221 Newly scored	9.1	CRIT		0.001	misp-project:misp	MISP contains an improper TLS certificate validation vulnerability in CurlClient. The CurlClient::\$verifyPeer property was not explicitly initialized and therefore defaulted to null. When passed to cURL, this value effectively disabled TLS peer verification unless the calling code explicitly enabled it. As a result, HTTPS connections made through affected CurlClient instances could accept certificates that were ...
CVE-2026-86729 Newly scored	9.1	CRIT		0.002		WWBN AVideo through commit e01e41ecc (no patched version available) exposes get_api_preauthorize in plugin/API/API.php as a second, undocumented login path. Unlike get_api_signIn, which enforces a rate limit of 10 attempts per 5 minutes via checkRateLimit(), get_api_preauthorize performs the same credential check with no throttling for any client, allowing unlimited remote password guessing against arbitrary accou...
CVE-2026-86840 Newly scored	9.1	CRIT		0.002		The `vtoken-minting` and `slpx` pallets in Bifrost contain an improper authorization vulnerability in channel commission attribution. A signed account can supply an arbitrary registered `channel_id` when minting tokens without verifying that the caller is authorized to mint on behalf of that channel. This allows an attacker to inflate a channel's recorded mint volume and cause protocol commission payments to be di...
CVE-2026-88007 New	9.1	CRIT		0.003	traefik:traefik fixed: 2.11.57, 3.7.13	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backend keep-alive, an unr...
CVE-2026-88008 New	9.1	CRIT		0.003	traefik:traefik fixed: 2.11.57, 3.7.13	Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.26 until 2.11.57 and 3.7.13, Traefik forwards a client-supplied Connection header requesting Upgrade, the Upgrade: h2c token, and HTTP2-Settings to a shared backend. If the backend accepts h2c and returns 101 Switching Protocols, Traefik enters a raw tunnel and no longer applies routers, BasicAuth, ForwardAuth, IPAllowList, RateLimit, access...
CVE-2026-88044 New	9.1	CRIT		0.005	go:github.com/rclone/rclone fixed: 1.75.1	rclone is a command-line program to sync files and directories to and from different cloud storage providers. From 1.70.0 until 1.75.1, the serve/start RC interface accepts per-server proxyOpt.AuthProxy settings, and the FTP and S3 constructors in cmd/serve/ftp/ftp.go and cmd/serve/s3/server.go incorrectly check the process-global proxy.Opt.AuthProxy value instead. When the global value is empty, the request-local...
CVE-2026-89086 New	9.1	CRIT		0.002		In the jose package before 0.11.0 for OCaml, library calls to validate an RSA signature only confirm that PKCS #1 decoding succeeds, and proceed to declare the signature valid without the required steps that involve the public key.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85982 Newly scored	9.0	CRIT		0.002		The Auth0 AD/LDAP Connector is vulnerable to stored Cross-Site Scripting (XSS) issues due to improper HTML encoding of data in search results and updater log content displayed in the admin panel. An authenticated user with privileges to modify directory attributes, or a low-privileged local user on the host where the connector is installed, could insert script content. This script content could then execute in an ...
CVE-2026-86259 Newly scored	9.0	CRIT		0.003		OpenMAIC before 1.0.1 skips server-side request forgery validation in non-production builds, allowing unauthenticated attackers to reach cloud instance metadata services. Attackers can supply arbitrary provider URLs via the x-base-url header or baseUrl parameter to access sensitive cloud credentials and metadata.

Watchlist matches (other priorities)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73006 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73016 Newly scored	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-80083 Newly scored	8.8	HIGH		0.002	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-80096 Newly scored	8.8	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-83992 Newly scored	8.8	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-47879 Newly scored	8.7	HIGH		0.003	vmware:spring_cloud_gateway	Spring Cloud Gateway JsonToGrpcGatewayFilterFactory allows arbitrary Spring Resource locations for defining the proto descriptor. Spring Cloud Gateway 5.0.0 - 5.0.2 Spring Cloud Gateway 4.3.0 - 4.3.5 Spring Cloud Gateway 4.0.0 - 4.2.9 Spring Cloud Gateway 3.1.13 and earlier

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55250 Newly scored	8.7	HIGH		0.006		Maravel, a PHP framework oriented towards dependency injection, prior to version 10.74.0 has a high-severity Token Replay Vulnerability arising from a structural lifecycle mismatch between stateless token validation engines and high-performance relational caching layers. Any application with low cache memory that causes premature eviction to free up memory and applications running macropay-solutions/maravel-framew...
CVE-2026-62243 Newly scored	8.7	HIGH		0.002		Netty (io.netty:netty-handler) versions from 4.2.0.Final through 4.2.16.Final and versions through 4.1.136.Final disable TLS hostname verification on the SslProvider.OPENSsl client path when a plain (non-extended) X509TrustManager is used and Unsafe-based trust-manager wrapping is unavailable (Java 25+). In this configuration the OpenSSL client does not perform hostname verification, allowing a man-in-the-middle a...
CVE-2026-84694 Newly scored	8.7	HIGH		0.005		Coolify before 4.2.0 fails to properly escape environment variable key names in Docker commands executed over SSH on managed servers. Authenticated attackers can inject shell metacharacters into environment variable keys to execute arbitrary commands on the server host outside containers.
CVE-2026-88874 New	8.7	HIGH		0.005		AVideo through revision c3edcc274c389816d434acadac07ee78eaf330c1 (master, 2026-08-23) does not enforce the Live stream password check on the stats endpoint or on the HLS origin. Live::_getStats() (plugin/Live/Live.php) returns a password-protected transmission's RTMP stream key, its isPasswordProtected flag, and its HLS (m3u8) URL to unauthenticated callers, in both the public applications list and the hidden_appl...
CVE-2026-82461 Newly scored	8.6	HIGH		0.002		pac4j-oidc before 6.5.6 fails to verify access token signatures, issuers, audiences, or expiry when extracting Keycloak realm and client roles. Attackers can forge access tokens with administrative roles paired with valid ID tokens to bypass authorization checks in applications relying on pac4j role validation.
CVE-2026-88880 New	8.6	HIGH		0.004		Renovate before 44.11.3 fails to validate Link header destinations when following GitLab server pagination, allowing malicious servers to redirect credential-bearing requests. Attackers controlling a compromised GitLab server can specify a Link header pointing to attacker-controlled infrastructure to exfiltrate authentication credentials.
CVE-2026-6958 Newly scored	8.5	HIGH		0.001		Acunetix 25.11.251107123 for Windows contains a local privilege escalation vulnerability in the Web Vulnerability Scanning Engine (wvsc.exe) that allows low-privileged local attackers to execute arbitrary code as SYSTEM by exploiting a missing hardcoded directory path for OpenSSL-related files. Attackers can create the missing directory, place a malicious file at the expected path, and cause the SYSTEM-level wvsc....
CVE-2026-88886 New	8.5	HIGH		0.002		Renovate is a dependency update automation tool. In versions before 44.14.7 (and in Mend Renovate CE/EE distributions before 15.4.0, and the mend-renovate-enterprise-edition Helm chart before 10.4.0), the manager/gradle-wrapper module does not escape the distributionUrl value read from a repository's gradle/wrapper/gradle-wrapper.properties file before invoking the Gradle Wrapper CLI. In self-hosted deployments co...
CVE-2026-88889 New	8.5	HIGH		0.006		Renovate before 44.14.7 contains a command injection vulnerability in the Maven Wrapper manager that allows attackers to execute arbitrary commands by specifying a malicious distributionType parameter in maven-wrapper.properties. Attackers can inject shell commands through unescaped distributionType values to achieve remote code execution when Renovate processes Maven Wrapper updates in binarySource=docker mode.
CVE-2026-88022 New	8.4	HIGH		0.003		Improper neutralization of special elements in data query logic in the MongoDB integration for Laravel can cause an array supplied to an explicit equality filter to be interpreted as a query condition rather than as a literal value. This affects the three-argument `where` method when the operator is `=` or `eq`, as well as the `find` and `delete` methods that use that code path. An attacker who can cause an affect...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88033 New	8.3	HIGH		0.003	mongodb:java_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Java Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-81354 Newly scored	8.2	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-89054 New	8.2	HIGH		0.004		A missing authorization vulnerability in OpenNMS Horizon allows configuration changes without authentication. The Spring Security policy for the /api/v2 REST API defines authorization rules for every HTTP method except PATCH, so the shipped @PATCH configuration endpoints for event configuration and SNMP data collection (which enable and disable event definitions and data-collection sources) are reachable with no a...
CVE-2026-69620 Newly scored	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-78626 Newly scored	8.1	HIGH		0.002		The Okta Access Gateway improperly handles input sanitization and regular expression evaluation within its Protected Rule authorization check, resulting in an authorization bypass when an administrator has explicitly configured a Protected Rule policy on one or more application resources.
CVE-2026-84393 Newly scored	8.1	HIGH		0.002		A improper validation of certificate with host mismatch vulnerability in Fortinet FortiOS 7.6.1 through 7.6.6, FortiProxy 7.6.2 through 7.6.6 may allow attacker to information disclosure via <insert attack vector here>
CVE-2026-87958 New	8.1	HIGH		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 is vulnerable to a denial of service where a specific functionality on a Db2 server can be disabled by a privileged user under certain conditions.
CVE-2026-9327 New	8.1	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.
CVE-2026-69847 Newly scored	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69876 Newly scored	8.0	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69298 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69323 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69580 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72990 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72995 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73001 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73011 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73021 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73026 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83498 Newly scored	7.8	HIGH		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Untrusted pointer dereference in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to elevate privileges locally.
CVE-2026-83942 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authorization in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-83952 Newly scored	7.8	HIGH		0.002	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Heap-based buffer overflow in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-83955 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83968 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83969 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83974 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83976 Newly scored	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83979 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78623 Newly scored	7.7	HIGH		0.002		The Okta Access Gateway does not sanitize SAML assertion values before interpolating them into database queries in the advanced mode datastore configuration. The unsanitized values are substituted directly into the query string prior to preparation, resulting in unintended SQL execution against the configured backend database.
CVE-2026-47885 Newly scored	7.5	HIGH		0.003	vmware:spring_framework	The PartEventHttpMessageReader in Spring WebFlux does not enforce the maxPartSize limit when maxInMemorySize is set to -1. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28
CVE-2026-47886 Newly scored	7.5	HIGH		0.003	vmware:spring_framework	Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack when the power operator (^) is used with a BigDecimal or BigInteger operand and a large exponent value. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framew...
CVE-2026-47888 Newly scored	7.5	HIGH		0.003	vmware:spring_framework	A Spring RSocket application is exposed to a memory leak via a malformed SETUP frame. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.0.RELEASE - 5.2.25.RELEASE
CVE-2026-47889 Newly scored	7.5	HIGH		0.003	vmware:spring_framework	A WebFlux application running on the Jetty 12 Core reactive adapter serializes response cookies without the sameSite attribute. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-69803 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69929 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-69930 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.
CVE-2026-70065 Newly scored	7.5	HIGH		0.012	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-70124 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to disclose information over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78523 Newly scored	7.5	HIGH		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Use after free in Windows DNS allows an unauthorized attacker to deny service over a network.
CVE-2026-78574 Newly scored	7.5	HIGH		0.001		The Okta Hyperdrive Integration plugin resolves a required assembly using a registry path within the current user's hive without integrity verification. The referenced path is loaded via Assembly.LoadFrom without signature validation, resulting in an unverified assembly executing within the context of the host process or elevated installer.
CVE-2026-86093 New	7.5	HIGH		0.005	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an attacker with the ability to control or impersonate a DRDA server endpoint to execute arbitrary commands on Db2 clients due to a stack-based buffer overflow that improperly copies user-controlled data into a fixed-size stack buffer without bounds checking.
CVE-2026-88032 New	7.5	HIGH		0.002	mongodb:java_driver	A use-after-free in the reactive client-side encryption component of the MongoDB Java Driver can cause native resources to be freed while an affected encrypted operation is still using them when the operation is cancelled. A party able to cause such an operation to be cancelled may cause the hosting application process to terminate. Reaching the issue requires an affected reactive encryption configuration that ret...
CVE-2026-9336 New	7.5	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted HTTP request to an administrative endpoint. A remote attacker could exploit this vulnerability to cause the server to exhaust filesystem space.
CVE-2026-47878 Newly scored	7.3	HIGH		0.003	broadcom:spring_batch	DefaultExecutionContextSerializer, used by default in Spring Batch's JDBC job repository, passes Base64-decoded bytes directly to ObjectInputStream.readObject() without an ObjectInputFilter that restricts types to a trusted class allowlist. Spring Batch 6.0.0 - 6.0.4 Spring Batch 5.2.6 and earlier
CVE-2026-78627 Newly scored	7.3	HIGH		0.001		The Okta Hyperdrive Integration installer does not mask the OAuth client secret when passed as an MSI property. The credential is recorded in plaintext in the installer log, the Application Event Log, and the process command line, all of which are readable by an authenticated local user on the workstation.
CVE-2026-88888 New	7.3	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the Mix manager when processing private dependencies with unescaped organization parameters. Attackers can inject shell metacharacters through malicious package names to execute arbitrary commands as the Renovate user in binarySource=docker mode.
CVE-2026-0310 New	7.2	HIGH		0.003		A buffer overflow vulnerability in the XML processing functionality of Palo Alto Networks PAN-OS® software enables an unauthenticated attacker with network access to the management web or dataplane interface to cause a denial of service (DoS) condition on VM-Series firewalls or execute arbitrary code with root privileges on the PA-Series firewalls. The security risk posed by this issue is minimized when the manag...
CVE-2024-14047 Newly scored	7.1	HIGH		0.001	elastic:winlogbeat	A local vulnerability in the Winlogbeat Windows installer caused runtime files to be placed in a directory writable by unprivileged users. A low-privileged attacker with existing access to the system could pre-position malicious filesystem links, causing a subsequent elevated Winlogbeat operation to write to or delete arbitrary files. Successful exploitation could result in a denial of service.
CVE-2026-87803 New	7.1	HIGH		0.002		An authorization bypass vulnerability exists in the Countly Server DBViewer due to flawed sub-pipeline detection in the aggregation stage sanitizer. The /o/db aggregation endpoint parses user-controlled aggregation JSON and passes it through a stage sanitizer that determines whether a nested array is a sub-pipeline by checking if every element contains a key present in a hardcoded KNOWN_STAGE_OPERATORS set. If any...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88026 New	7.1	HIGH		0.002		Improper neutralization of regular-expression metacharacters in the LINQ query translation component of the MongoDB C# Driver can cause a caller-supplied character sequence to alter a regular-expression predicate generated by an affected application. An authenticated user who can influence such a value may cause the application to return records beyond those intended by the original filter.
CVE-2026-88027 New	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the embedded-document relation handling of the MongoDB integration for Laravel can cause a caller-supplied embedded record identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence such an identifier may delete all embedded documents in a targeted record or overwrite an embedded d...
CVE-2026-88028 New	7.1	HIGH		0.002		Improper neutralization of special elements in data query logic in the polymorphic relation handling of the MongoDB integration for Laravel can cause a caller-supplied relation identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence a stored relation identifier may cause an affected application to return a document other than the intended relat...
CVE-2026-9176 New	7.1	HIGH		0.001	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-80093 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-83940 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-88885 New	7.0	HIGH		0.005		Renovate before 44.14.7 contains a command injection vulnerability in the gomod manager when processing unescaped depName parameters in import-path update commands with binarySource=docker mode. Attackers can inject shell metacharacters through malicious dependency names to execute arbitrary commands as the Renovate user during Go module major version updates with postUpdateOptions gomodUpdateImportPaths enabled.
CVE-2025-15613 Newly scored	6.9	MEDI		0.003		Kyverno before v1.13.4 is vulnerable to server-side request forgery (SSRF) via its Service Call functionality. An attacker with permission to create Kyverno (Cluster)Policies can specify an external URL in a policy's apiCall/service configuration; although Service Call is documented for in-cluster services, it also resolves external addresses, allowing requests to an attacker-controlled server. Because policy cont...
CVE-2026-84968 Newly scored	6.9	MEDI		0.002	mongodb:php_driver	An out-of-bounds read in the BSON decoding component of the MongoDB PHP driver may allow an unauthenticated party who supplies specially formed input to have a small amount of adjacent process memory copied into an error message that is returned to application code. This may result in unintended disclosure of limited memory contents.
CVE-2026-88884 New	6.9	MEDI		0.002		Renovate is a dependency update automation tool. In versions before 44.3.1 (and Mend Renovate CE/EE images before 15.4.0, mend-renovate-ce Helm chart before 15.4.0, mend-renovate-enterprise-edition Helm chart before 10.4.0), digest updates are not subject to the internal `minimumReleaseAge` (stability age) checks. When a repository configures `minimumReleaseAge` and has dependencies with `updateType=digest` — for ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78579 Newly scored	6.8	MEDI		0.002		The Okta Access Gateway does not sanitize SAML assertion attribute values before interpolating them into LDAP search filters in the LDAP datastore configuration. The raw values are substituted directly into the filter string and passed to the LDAP search operation, resulting in modification of the intended query logic.
CVE-2026-78625 Newly scored	6.7	MEDI		0.002		The Okta Access Gateway does not sanitize dashboard label values before writing them into generated PHP configuration files. The generated file is automatically included during authentication requests, resulting in execution with the privileges of the web server process.
CVE-2026-78630 Newly scored	6.7	MEDI		0.002		The Okta Access Gateway does not neutralize shell metacharacters in SNMP configuration values before a privileged script uses them to construct OS commands. An authenticated local user with access to the management interface can supply crafted values, resulting in the execution of arbitrary OS commands with root privileges.
CVE-2026-78545 Newly scored	6.6	MEDI		0.004		The Okta Access Gateway does not sanitize the application label field before including it in the generated nginx configuration file. The unsanitized value is interpolated into an nginx server block directive, resulting in execution of injected directives.
CVE-2026-78550 Newly scored	6.6	MEDI		0.004		The Okta Access Gateway management console passes user-supplied input to eval() without sanitization during an authenticated administrator SSH session. As a result, the unsanitized input is executed directly, leading to code execution with the privileges of the management console.
CVE-2026-69781 Newly scored	6.5	MEDI		0.005	microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:windows_server_2025	Missing release of memory after effective lifetime in Windows DHCP Client allows an unauthorized attacker to deny service over an adjacent network.
CVE-2026-88770 New	6.5	MEDI		0.002		A flaw was found in the Device Authorization Grant flow of Keycloak, an identity and access management solution. The issue occurs because the token redemption process fails to check if a user account is currently locked due to brute-force protection. If an attacker has an active session for a locked account, they can complete the device login process and receive new security tokens. This allows the attacker to mai...
CVE-2026-69878 Newly scored	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Heap-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code locally.
CVE-2026-47883 Newly scored	6.1	MEDI		0.002	vmware:spring_framework	UrlHandlerFilter can be vulnerable to an open redirect when configured with very broadly matching patterns. The issue applies to the filter variants in both Spring MVC and Spring WebFlux. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19
CVE-2026-47887 Newly scored	6.1	MEDI		0.002	vmware:spring_framework	A Spring MVC application that uses UriFileNameViewController that is mapped with an end-of-path, and does not have a configured prefix is vulnerable to an open redirect. Spring Framework 7.0.0 - 7.0.8 Spring Framework 6.2.0 - 6.2.19 Spring Framework 6.1.0 - 6.1.28 Spring Framework 6.0.0 - 6.0.30 Spring Framework 5.3.0 - 5.3.49 Spring Framework 5.2.25.RELEASE and earlier
CVE-2026-88023 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB PHP Library can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88024 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Rust Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88025 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C# Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file c...
CVE-2026-88029 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Python Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS fi...
CVE-2026-88030 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Ruby Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file...
CVE-2026-88031 New	6.1	MEDI		0.003		Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB Go Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may cause all GridFS file chunks in the affected bucket to be removed, rendering sto...
CVE-2026-88034 New	6.1	MEDI		0.003	mongodb:c\+\+_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C++ Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ...
CVE-2026-88036 New	6.1	MEDI		0.003	mongodb:c_driver	Improper neutralization of special elements in data query logic in the GridFS component of the MongoDB C Driver can cause a caller-supplied structured file identifier to be interpreted as a query condition rather than as a literal identifier. An authenticated user who can influence the identifier passed by an affected application may obtain stored file content beyond the intended target or cause all GridFS file ch...
CVE-2026-78552 Newly scored	6.0	MEDI		0.003		The Okta Access Gateway does not apply its Lua directive restriction to the application-level custom configuration field. The field is interpolated directly into the nginx server block without inspection, resulting in execution of injected directives.
CVE-2026-78622 Newly scored	6.0	MEDI		0.001		The Okta Verify for Windows uninstaller does not verify whether the user data directory is a filesystem junction before deleting its contents with elevated privileges. The delete operation follows the junction target, resulting in recursive deletion of unintended directory contents.
CVE-2026-78620 Newly scored	5.9	MEDI		0.003		The Okta Access Gateway Kerberos configuration handler does not validate file paths specified in event payloads before writing file contents. The path from the event payload is used directly as the write destination, resulting in files being written to unintended locations on the appliance filesystem.
CVE-2026-84970 Newly scored	5.8	MEDI		0.001	mongodb:c\+\+_driver	A numeric truncation weakness exists in the JSON parsing component of the MongoDB C++ Driver's BSON library. An actor who controls the text that an embedding application hands to the library's public JSON parsing interface, when that text is very large, can cause the library to read memory beyond the supplied buffer and return it to the caller, to silently accept only part of the input as a complete document, or t...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78629 Newly scored	5.6	MEDI		0.001		The Okta Hyperdrive agent plugin returns a success response without a signed SAML assertion when the organization's policy requires no MFA for a given user. The response contains only a bare boolean validation indicator with no cryptographic artifact, resulting in an unverifiable authentication verdict being delivered to the relying application.
CVE-2026-73008 Newly scored	5.5	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of private personal information to an unauthorized actor in Windows Biometric Service allows an authorized attacker to disclose information locally.
CVE-2026-83501 Newly scored	5.5	MEDI		0.003	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Out-of-bounds read in Windows Virtualization-Based Security (VBS) Enclave allows an authorized attacker to disclose information locally.
CVE-2026-86213 Newly scored	5.5	MEDI		0.003		A vulnerability was found in Mstfakts College-Management-System. This issue affects the function mysqli_query of the file Front-end/university.php of the component Search Handler. The manipulation of the argument book_name/book_author results in sql injection. The attack may be performed from remote. The exploit has been made public and could be used. This product utilizes a rolling release system for continuous d...
CVE-2026-88035 New	5.5	MEDI		0.001	mongodb:c_driver	A size check in the client-side authentication path of the MongoDB C Driver can wrap around, so an unusually large user-name value is accepted and copied past the end of a small buffer. A party able to set the driver's connection settings may cause the application that embeds the driver to terminate unexpectedly. Reaching this code requires a build in which the optional external SASL authentication backend is pres...
CVE-2026-47880 Newly scored	5.4	MEDI		0.002	vmware:spring_integration	A producer who can publish to a JMS destination consumed by any Spring Integration JMS inbound component can set String JMS properties named replyChannel, errorChannel, or json__TypeId__ which are copied verbatim into the Spring Integration MessageHeaders. Spring Integration 7.1.0 Spring Integration 7.0.0 - 7.0.5 Spring Integration 6.5.0 - 6.5.10 Spring Integration 6.4.0 - 6.4.12 Spring Integration 5.5.21 and earlier
CVE-2026-69402 Newly scored	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-84385 Newly scored	5.4	MEDI		0.001		A improper access control vulnerability in Fortinet FortiSOAR PaaS 7.6.0 through 7.6.6, FortiSOAR PaaS 7.5.0 through 7.5.3, FortiSOAR PaaS 7.4 all versions, FortiSOAR PaaS 7.3 all versions, FortiSOAR on-premise 7.6.0 through 7.6.6, FortiSOAR on-premise 7.5.0 through 7.5.3, FortiSOAR on-premise 7.4 all versions, FortiSOAR on-premise 7.3 all versions may allow attacker to escalation of privilege via <insert attack v...
CVE-2026-16660 Newly scored	5.3	MEDI		0.004	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 could allow a remote attacker to cause a denial of service due to an out-of-bounds read.
CVE-2026-78631 Newly scored	5.3	MEDI		0.001		The Okta Hyperdrive Agent writes the decoded SAML bearer assertion to a local application log file at the default log level on every successful MFA completion. This insertion of sensitive information into the log file makes a live authentication credential readable by any local user with access to the log file.
CVE-2026-9338 New	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a denial of service, caused by sending a specially-crafted request. A remote attacker could exploit this vulnerability to trigger excessive resource consumption, potentially leading to reduced availability of the affected service.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-9667 New	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2026-78635 Newly scored	5.0	MEDI		0.002		The Okta Privileged Access client URL handler does not insert an option terminator before appending the target value to the command-line arguments. When a scaleft:// protocol handler link contains a value beginning with a hyphen, the underlying CLI framework interprets it as a command-line flag, causing unintended modification of the SSH client's behavior.
CVE-2026-78624 Newly scored	4.9	MEDI		0.004		The Okta Access Gateway backup restore function does not validate the filename embedded in an encrypted backup payload. This results in writing file contents to unintended locations on the appliance filesystem.
CVE-2026-69615 Newly scored	4.8	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-78560 Newly scored	4.8	MEDI		0.002		The Okta Access Gateway includes an optional pass-through authentication source that accepts user identity from a client-supplied HTTP header without cryptographic validation. In architectures where this optional source is enabled without an upstream reverse proxy or firewall configured to sanitize and enforce client headers, an unauthenticated user can supply an arbitrary identity value to initiate a session.
CVE-2026-78508 Newly scored	4.6	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows CD-ROM Driver allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-78516 Newly scored	4.3	MEDI		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Buffer over-read in Windows Storage allows an unauthorized attacker to disclose information with a physical attack.
CVE-2026-86087 New	4.3	MEDI		0.002	ibm:db2	IBM Db2 11.5.0 through 11.5.9, and 12.1.0 through 12.1.5 could allow an authenticated user to send a specially crafted request to write arbitrary files on the system.
CVE-2026-84969 Newly scored	3.7	LOW		0.002	mongodb:c_driver	A memory-handling error in the BSON-to-JSON conversion helpers of the MongoDB C Driver can write a small number of bytes past the end of a heap buffer when a binary field is encoded and the output is cut short at a caller-configured length limit. A party who supplies the document content, with no privileges on the application that links the driver, may cause a small amount of data outside the intended buffer to be...
CVE-2026-17483 Newly scored	3.3	LOW		0.002	ibm:db2_mirror_for_i	IBM Db2 Mirror for i 7.4, 7.5, and 7.6 IBM i could allow a local attacker to delete historical flight-recorder archives due to improper access control in an SQL procedure.
CVE-2026-84389 Newly scored	3.1	LOW		0.001		A url redirection to untrusted site ('open redirect') vulnerability in Fortinet FortiSIEM 7.5.0 through 7.5.1, FortiSIEM 7.4.1 through 7.4.2 may allow attacker to execute unauthorized code or commands via <insert attack vector here>
CVE-2026-55253 New				0.004	PyPI:langgraph-checkpoint-mongod b fixed: 0.3.0	# Executive Summary A NoSQL injection issue exists in the langgraph-checkpoint-mongodb and langgraph-store-mongodb libraries. MongoDBSaver.list() and MongoDBStore.search() methods accept a filter parameter that is incorporated into MongoDB queries without sufficient validation. Because MongoDB query operator keys (those prefixed with \$) are not rejected during filter construction, a caller with control of the fil...

P3/P4 items (1025) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.